Report

Broken Function Level Authorization

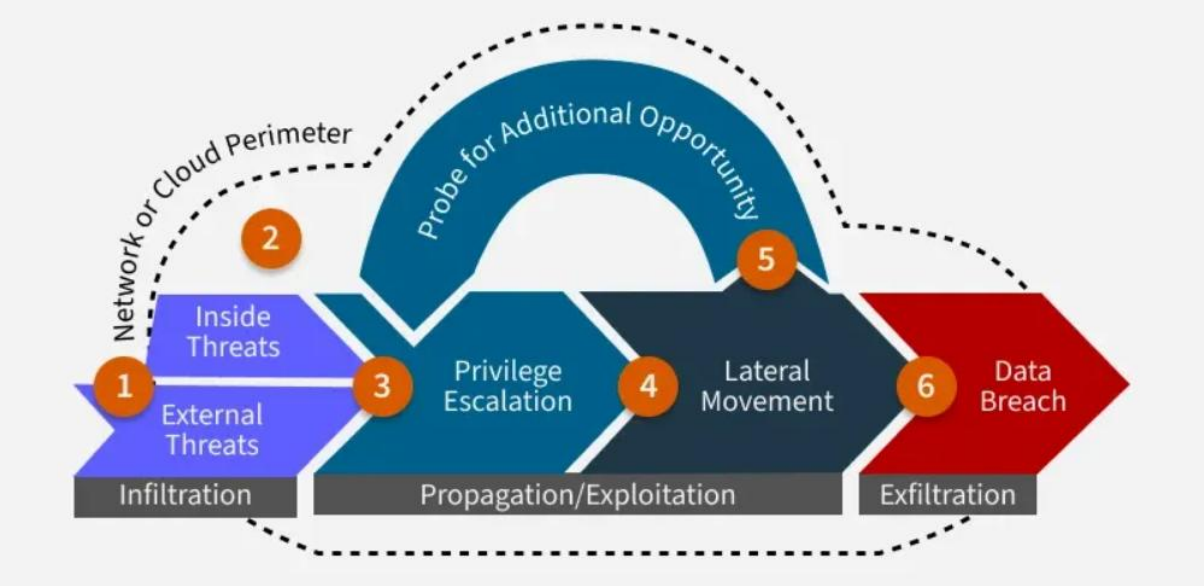
Suyash A Gunjal

Broken Function Level Authorization

What is Privilege Escalation

A privilege escalation attack is a type of cyberattack in which an attacker gains unauthorized access to elevated rights, permissions, entitlements, or privileges beyond those originally assigned to a user, account, identity, or machine.

Privilege escalation is a critical phase in the cyberattack chain and often involves exploiting vulnerabilities such as system bugs, misconfigurations, or weak access controls. By leveraging these weaknesses, attackers can move laterally within a system, gain administrative control, or access sensitive data.



What Is Broken Function Level Authorization (BFLA)?

Broken Function Level Authorization (BFLA) is a security vulnerability where a user can access unauthorized functionalities of a system. It arises when applications or APIs do not properly validate or enforce permission checks for accessing their functions, allowing users to execute actions beyond their permissions.

BFLA threats are significant because they can let users perform sensitive operations they shouldn't access, such as modifying or deleting data, changing

user permissions, or accessing confidential information. This vulnerability is commonly found in systems with complex user roles or permissions.

Broken Function Level Authorization vs. Broken Object Level Authorization

Broken Function Level Authorization and Broken Object Level Authorization (BOLA) both deal with improper enforcement of access controls, but one focuses on unauthorized access to functionality, while the latter deals with access to objects or data. BFLA is about functions or actions a user can perform, while BOLA involves accessing, modifying, or deleting specific data entities.

BFLA can significantly compromise system integrity and confidentiality by allowing unauthorized users to perform actions they are not entitled to. This can lead to unauthorized data manipulation, privilege escalation, or access to restricted functionalities, potentially affecting the entire application or system. The risk is especially high in systems where functionalities are closely tied to sensitive operations or data.

BOLA affects data confidentiality and integrity on a more granular level. Unauthorized access to specific objects or data records can lead to data breaches, unauthorized data modifications, or deletion. The impact is limited to the affected data entities but can have broader implications if the exploited objects are critical to the application's functionality or security.

What Does a BFLA Attack Look like?

Legitimate – POST method is correctly requested	Attack – Request is modified to send a DELETE method
POST /example/api/v1/provision/user/search HTTP/1.1 User-Agent: AHC/1.0	DELETE /example/api/v1/provision/user/search HTTP/1.1 User-Agent: AHC/1.0

Connection: keep-alive
Accept: */*
Content-Type: application/json;
charset=UTF-8
Content-Length: 131
X-Forwarded-For: 10.93.23.4
 	
{
"search_filter":
"user_id=exampleId_100",
"max_return": "250",
"page_size": "250",
"return_attributes": [
 	
]
}
	Connection: keep-alive
	Accept: */*
	Content-Type: application/json;
	charset=UTF-8
	Content-Length: 131
	X-Forwarded-For: 10.93.23.4
	
	{
	"search_filter":
	"user_id=exampleId_100",
	"max_return": "250",
	"page_size": "250",
	"return_attributes": [
	
	]
	}

In the example above, the attacker has changed the method from POST. to DELETE allowing them to delete the account associated with user_id=exampleId_100. Access to the DELETE method should have been restricted to users with administrative access but was allowed due to an inadequate authorization policy.

How To Prevent broken function level authorization?

Your application should have a consistent and easy-to-analyze authorization module that is invoked from all your business functions. Frequently, such protection is provided by one or more components external to the application code.

- The enforcement mechanism(s) should deny all access by default, requiring explicit grants to specific roles for access to every function.
- Review your API endpoints against function level authorization flaws, while keeping in mind the business logic of the application and groups hierarchy.
- Make sure that all of your administrative controllers inherit from an administrative abstract controller that implements authorization checks based on the user's group/role.
- Make sure that administrative functions inside a regular controller implement authorization checks based on the user's group and role.

References:

https://salt.security/blog/api5-2023-broken-function-level-authorization

https://www.pynt.io/learning-hub/owasp-top-10-guide/broken-function-level-authorization-how-it-works-and-4-preventive-measures